

# AI Critique — Đánh giá Năng lực và Hạn chế của AI trong Kiểm thử API

Họ tên sinh viên: PHẠM ĐỨC TOÀN

MSSV: 23127540 — Lớp: 23KTPM2

Bài tập: HW06 – API Testing (CS423 / CSC13003)

Mô hình AI sử dụng: Gemini 3.6 Flash / Gemini 3.7 Flash — Antigravity AI IDE

Số lượng từ: ~275 từ (đáp ứng chuẩn 200–300 từ)

Trong quá trình thực hiện bài tập kiểm thử API cho hệ thống EShop (bao gồm FR-01, FR-06, FR-07 và FR-12), việc hợp tác với AI đã bộc lộ rõ cả điểm mạnh vượt trội lẫn những hạn chế chí mạng của mô hình ngôn ngữ lớn (LLM).

AI thể hiện xuất sắc ở khả năng sinh mã boilerplate nhanh chóng: cấu trúc kịch bản phân vùng tương đương chuẩn mực, sinh file Postman collection JSON phức tạp và thiết kế sơ đồ kiến trúc Agent Skill. Tuy nhiên, AI gặp sai sót và phiến diện nghiêm trọng khi đánh giá tính bảo mật và logic trạng thái nghiệp vụ (State Machine). Cụ thể, khi sinh test case cho các API Admin (FR-12), AI mặc định gán kết quả mong đợi là `403 Forbidden` khi người dùng thông thường gửi request vì nó ngây thơ tin rằng hệ thống đã cài đặt phân quyền. Nhưng thực tế trong mã nguồn `server.js`, middleware xác thực hoàn toàn không kiểm tra `req.user.role === 'admin'`, cho phép user thường truy cập trái phép toàn bộ dữ liệu quản trị (Lỗi hỏng Broken Access Control SEC-01). Tương tự, AI bỏ sót hoàn toàn lỗi thăng quyền Mass Assignment tại `PUT /api/users/me` và lỗi gian lận giá tiền Price Tampering tại `POST /api/cart`.

Nguyên nhân AI thất bại là do LLM luôn suy luận dựa trên tài liệu đặc tả lý tưởng (Specification-first Bias) thay vì phân tích dòng chảy thực thi thực tế của mã nguồn (Execution-path Reality). Bài học cốt lõi rút ra khi cộng tác với AI trong kiểm thử phần mềm là: **"AI là công cụ gia tốc tạo kịch bản, nhưng con người bắt buộc phải là chốt chặn kiểm chứng an ninh và logic nghiệp vụ"**. Kỹ sư kiểm thử không bao giờ được chấp nhận mù quáng kết quả do AI sinh mà phải luôn đối soát với mã nguồn thực tế và thực hiện Dynamic Security Testing.